

Penetration testing Course

Rubric 1

Initial Exploitation Report

Engagement title: Home Lab Internal Network Assessment **Phase:** PTES Phase 5 (Exploitation) **Document version:** 1.0 **Classification:** Confidential — Lab Use Only **Prepared by:** [Your name], DAE Cybersecurity Program **Date:** [Fill in] **Related documents:** R1 Engagement Plan, R2 Recon, R3 Vulnerability Assessment, R4 Network Testing

Same engagement, same authorized target (192.168.78.5), same signed authorization. Every action below is performed **only** against your own lab VM. Running these techniques against any system you do not own and have written permission to test is illegal — that boundary is part of the professional methodology this rubric grades. Placeholders in [brackets] are yours to fill.

Table of Contents

1. Objectives & Scope
 2. Safety Controls & Rules of Engagement
 3. Exploitation Methodology
 4. Service Exploitation (Telnet Access)
 5. Password Attacks (Controlled Demonstration)
 6. Proof of Concept
 7. Impact Assessment
 8. Evidence Log
 9. Appendix A — Tool Reference
 10. Appendix B — Ethics & References
-

1. Objectives & Scope

Objectives:

1. Demonstrate a methodical, safety-first exploitation process.
2. Perform basic service exploitation in the controlled lab.

3. Demonstrate password attacks with appropriate tools against a controlled test account.
4. Produce a documented proof of concept (PoC) for the confirmed vulnerability.

In scope: 192.168.78.5 only. **Out of scope:** everything else — the host OS, the router, any other device, and the public internet.

2. Safety Controls & Rules of Engagement

This section is graded as heavily as the exploitation. Set these up *before* touching anything.

Control	Action	Why
Snapshot	Take a VirtualBox snapshot of the VM before starting	Instant rollback if anything breaks
Isolation	Confirm the VM is on an isolated host-only/internal network	Attacks never reach anything outside the lab
Test account	Create a dedicated weak account for password-attack testing (Section 5) — do not attack the real vboxuser account with automated tools	Keeps the real account safe and makes the demo controlled and repeatable
Rate limiting	Use low thread counts (-t 4) on any password tool	Avoids overwhelming the service and mimics responsible testing
Non-destructive	No deleting data, no denial-of-service	Stays within ROE
Stop condition	If the VM becomes unstable, stop and restore the snapshot	Safety first
Cleanup	Remove the test account and any test artifacts when done	Leaves the environment clean

Record that each control was in place — that documentation *is* the deliverable for "proper safety controls."

3. Exploitation Methodology

A methodical exploitation follows a disciplined order, from least to most invasive:

1. **Confirm the vulnerability is real** (done in R3/R4 via the packet capture).
2. **Choose the least-invasive path** that proves impact. Prefer using legitimately obtained credentials over noisy attacks.
3. **Attempt access in the controlled environment**, documenting each step.
4. **Verify and capture proof** (screenshots, command output).
5. **Assess impact** — what the access actually exposes.
6. **Stop at proof of concept**. You demonstrate the risk; you don't cause damage.

This mirrors professional practice: the goal is to *prove* the vulnerability, not to maximize destruction.

4. Service Exploitation (Telnet Access)

The telnet weakness doesn't require an "exploit" in the memory-corruption sense — the exploitation is **using credentials to gain a shell**, which is the natural consequence of the cleartext-credential finding from R3/R4.

4.1 Method

Using the credentials recovered from the traffic capture (R4), authenticate to the target over telnet:

```
telnet 192.168.78.5 23
```

```
# log in with the credentials observed in the packet capture
```

4.2 Result

A successful login returns an interactive shell on the target as that user. Capture:

- the login succeeding, and
- a command proving you're on the target, e.g. `hostname && whoami && id`.

This is the exploitation PoC for the primary finding: **sniffed cleartext credentials** → **interactive shell on the target**. It chains directly from the R4 capture, which is what makes your engagement coherent end to end.

5. Password Attacks (Controlled Demonstration)

This demonstrates the standard tools and techniques on a **deliberately weak test account you create** — the controlled-lab pattern. You set up the vulnerability, then show the tool finding it.

5.1 Concepts

Attack type	Where it runs	How it works
Online (direct)	Against the live service	Tries username/password pairs against the login prompt
Offline (cracking)	Against captured password hashes	Hashes candidate passwords and compares to stolen hashes; faster and stealthier
Dictionary	Either	Tries words from a wordlist (most real passwords are guessable words)
Brute force	Either	Tries every combination; only feasible for short passwords

5.2 Set up the controlled test account (on the VM)

```
sudo useradd -m testuser
```

```
echo 'testuser:Password123' | sudo chpasswd
```

Build a small wordlist that *includes* the known password, so the demo is deterministic:

```
printf 'admin\nletmein\nPassword123\nqwerty\n' > wordlist.txt
```

(Kali also ships the standard teaching wordlist [rockyou.txt](#) at `/usr/share/wordlists/` if you want a realistic dictionary.)

5.3 Online attack demonstration — Hydra vs. telnet

```
hydra -l testuser -P wordlist.txt telnet://192.168.78.5 -t 4
```

- `-l testuser` = the single test account (never the real account).

- `-P wordlist.txt` = the candidate passwords.
- `-t 4` = only 4 parallel attempts — the safety/rate-limit control.

Expected result: Hydra reports the valid password for `testuser`, demonstrating that a weak password on an exposed login service is recoverable. Screenshot the success line.

5.4 Offline attack demonstration — John the Ripper

Show the offline path on the same test account's hash (all local to the VM):

```
sudo unshadow /etc/passwd /etc/shadow > hashes.txt
```

```
john --wordlist=wordlist.txt hashes.txt
```

```
john --show hashes.txt
```

Expected result: John recovers the `testuser` password from its hash. This demonstrates why stolen hash files are dangerous even without the live service.

5.5 Safety notes

- Both demos target only `testuser`, on an isolated VM, with a snapshot taken.
 - Low thread count avoids stressing the service.
 - **Cleanup when finished:** `sudo userdel -r testuser` and delete `hashes.txt` / `wordlist.txt`.
-

6. Proof of Concept

PoC-01 — Credential-Based Compromise of Telnet Service Vulnerability:

Cleartext credential transmission (R3 finding VA-01) + weak-password susceptibility. **Target:** `192.168.78.5`, port 23/tcp. **Preconditions:** Attacker on the local segment; telnet service exposed. **Steps demonstrated:**

1. Credentials captured from cleartext telnet traffic (R4), **or** recovered via dictionary attack against a weak account (Section 5).
2. Authenticated to the telnet service with those credentials.
3. Obtained an interactive shell on the target (`whoami/id` confirming the account). **Result:** Interactive access to the target as the compromised user. **Evidence:** login screenshot, `id` output, Hydra/John success screenshots, R4 packet capture. **Safety:** performed on an isolated, snapshotted VM using a dedicated test account; no data altered.

7. Impact Assessment

- Access gained: interactive shell as `[user]`.
- If the compromised account has `sudo` rights (as `vboxuser` does), this is a path to **full administrative control** — which sets up the post-exploitation phase (privilege confirmation, persistence considerations, data exposure).
- This confirms the R3 risk rating of **High** was justified: the vulnerability is not theoretical; it yields real access.

(This section hands off to the next rubric — post-exploitation.)

8. Evidence Log

- ☐ Snapshot confirmation screenshot (safety control)
 - ☐ Telnet login success + `hostname && whoami && id` output
 - ☐ Hydra run showing recovered password for `testuser`
 - ☐ John the Ripper `--show` output
 - ☐ R4 packet capture referenced as credential source
 - ☐ Cleanup confirmation (`userdel`, files removed)
-

Appendix A — Tool Reference

Tool	Purpose	Type
telnet client	Authenticate to the service	Access
Hydra	Online password attack against a login service	Password attack
John the Ripper	Offline password hash cracking	Password attack
unshadow	Combine <code>/etc/passwd</code> + <code>/etc/shadow</code> into a crackable file	Support

Appendix B — Ethics & References

Ethics statement: All exploitation was performed on a system owned by the tester, under the signed authorization in R1, on an isolated network, with safety controls and cleanup. These tools and techniques are for authorized testing only. Unauthorized use against systems you do not own is a criminal offense.

- PTES — Exploitation phase — pentest-standard.org
- NIST SP 800-115, *Technical Guide to Information Security Testing and Assessment*
- OWASP Testing Guide — Authentication Testing
- Tool documentation: Hydra, John the Ripper (official project docs)

This report is for authorized security testing in a controlled lab environment only.